

FINALS XX



All Ports Tours

Cruise Line

Internal Security Assessment Report

Confidential

No part of this document may be disclosed without
the explicit written authorization of APT

1/10/2026

Version 2.0

Table of Contents

Statement of Confidentiality and Liability	2
Contact Information	3
Client Information	4
SOCAL-XX Contact Information	4
Version Information	4
Executive Summary	4
Engagement Overview	6
Network Topology	8
Strategic Remediation Plan	9
Technical Risk Assessment Metrics	10
Technical Findings	12
Remediation Summary	13
Critical Findings	15
C1: Weak Administrator Password	16
High Findings	17
H1: Weak Administrator Password	17
Medium Findings	19
M1: Public Access to WP-Cron.php	19
Low Findings	20
L1: SMTP Unenforced DKIM and DMARC	20
Informational Findings	22
I1: Excessively Privileged Application	22
Appendix	23
Appendix A – Compromised Accounts	24
Appendix B – Tools Used	24
Appendix C - Methodology	28
OWASP Top 10	28
Appendix D – CVSS 4.0	29
Appendix E – MITRE ATT&CK Framework	29

Confidential

Appendix F – Artifacts 29

Statement of Confidentiality and Liability

This assessment was conducted in accordance with the terms and conditions established by All Ports Tours Cruise Line, with all activities performed strictly within the authorized scope and procedures defined in the engagement overview. All findings and recommendations contained in this report are based on evaluations performed during the specified testing period.

Due to the limited timeframe and defined scope of the engagement, the findings presented herein should not be considered an exhaustive identification of all potential vulnerabilities or risks within All Ports Tours Cruise Line's network or systems. This report is provided solely for the purposes outlined in the engagement agreement and does not constitute legal, compliance, or regulatory advice.

Disclaimer:

This report is provided "as is," without any express or implied warranties, including, but not limited to, warranties of accuracy, completeness, merchantability, or fitness for a particular purpose. The authors and All Ports Tours Cruise Line shall not be held liable for any damages, losses, or other consequences arising from the use or reliance on this report beyond the intended scope of the engagement. Any reliance on this document is at the reader's own risk.

Contact Information

Client Information

Client	All Ports Tours
Primary Contact	Bailey Finn
Approvers	PERSON 1 PERSON 2

Note that all personnel indicated in the *Approvers* section are authorized to modify the scope and terms of engagement at their discretion.

SOCAL-XX Contact Information

Name	Team-XX Security Consulting
Address	
Phone	
Email	

Version Information

Version	Date	Description
1.0	11/01/2025	Initial Penetration Test for All Port Tours

Executive Summary

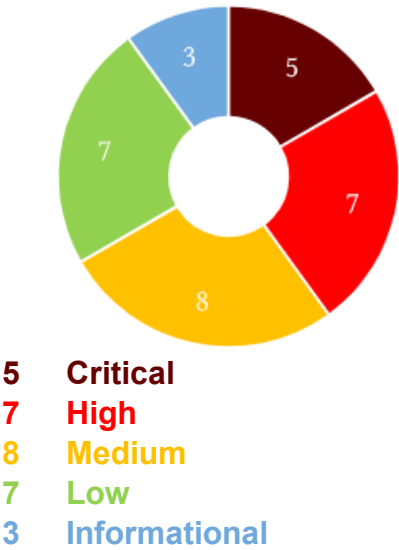
Throughout November 1st, FINALS-XX conducted a security assessment on All Ports Tours Cruise Line’s (APT) network **SPECIFY MULTIPLE NETWORKS HERE IF NECESSARY**. The assessment aimed to evaluate APT’s adherence to the best security practices, compliance with common standards, as well as the overall safety and well-being of any individuals relying on the analyzed systems.

This assessment identified **NUMBER** vulnerabilities deemed as critical, with a total of **NUMBER** findings of all types identified in the scope of the APT network. APT faces a **critical** risk of compromise, and immediate attention to the network is necessary.

To enhance overall security measures, **SOCAL-XX** has created a comprehensive and holistic security strategy to address and resolve these issues as described in **Section X, Strategic Plan**. In general, **SOCAL-XX** recommends that APTCL follow industry best practices, such as keeping services and systems up-to-date with regular patches and updates, implementing strong encryption and authentication, and strengthening access controls.

Additionally, it is advisable for APT to implement employee training programs, focusing on password reuse and complexity, alongside regularly scheduled sessions addressing the awareness and prevention of social engineering attacks. Implementing proactive steps such as these will contribute to the strength of the overall security posture of All Ports Tours Cruise Line.

Findings



Timeline

Assessment began
2025-date-here

Assessment concluded
2025-date-here

Report submitted
2025-date-here

Scope

IP addresses, cloud stuff, phishing here

Engagement Overview

TEAM NAME was contracted by **COMPANY** to perform a security assessment on the security posture of **Service**. This engagement was conducted with the purpose of extensively testing the in-scope networks from the perspective of a threat actor attempting to gain access to unauthorized resources.

The phases of the engagement are as outlined:

1. External Enumeration

The engagement began with external reconnaissance and enumeration. Industry standard tools and techniques were used to identify open ports, running services, and potential attack vectors in the environment.

2. Initial Foothold

Using information gathered during initial enumeration, we identified and exploited vulnerabilities that allowed us to gain an initial foothold within the target environment, often as a low-level user.

3. Privilege Escalation

Local privilege escalation techniques were employed to elevate our access from low-level accounts to ones with administrative or root privileges. This step allowed for broader control over affected machines and increased access to internal resources.

4. Internal Enumeration and Pivoting

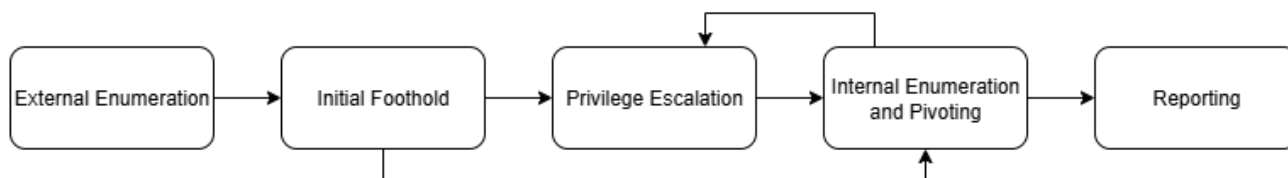
Following successful privilege escalation or initial footholds on high level users, we performed thorough internal network enumeration to map internal infrastructure and identify additional targets. Using our elevated access, we performed lateral movement across the network to compromise additional systems and expand our foothold. Techniques included **BLANK**.

5. Reporting

Upon completion of penetration testing, all findings were thoroughly documented and analyzed. This report presents a comprehensive overview of identified vulnerabilities. Each vulnerability finding includes a detailed technical descriptions, evidence of exploitation, risk ratings based on CVSS 4.0 scoring, and remediation

Confidential

recommendations. The report is structured to provide both executive-level summaries for strategic decision-making and technical details for security teams to implement effective countermeasures.



Scope of Evaluation:

Name	IP Range (CIDR) / Cloud Environment
XXXX Network	
XXXX Network	
XXX Network	

Provided Credentials:

User	Information

Network Topology

TEAM NAME conducted host discovery and enumeration across the defined in-scope subnets using industry-standard tools. Based on these findings, we constructed a network topology diagram to illustrate the structure of the **COMPANY** network.

Insert image of topology

Add pentesting methodology here

Strategic Remediation Plan

Throughout the assessment, Team-XX recognized multiple security controls implemented by APTCL. Team-XX recommends APTCL to continue upholding these controls to maintain its security posture. There are, however, key areas of improvement where additional security controls should be implemented. Refer to X.3 for a summary of this plan

X.1 Key Security Strengths

A. XXX

Details

B. XXX

Details

C. XXX

Details

X.2 Key Improvement Areas

A. XXX

Details

B. XXX

Details

C. XXX

Details

Technical Risk Assessment Metrics

To capture the principal characteristics of a vulnerability and produce a numerical score reflecting its severity, TEAM-XX used the [Common Vulnerability Scoring System V4.0](#) (CVSS 4.0). CVSS scores are commonly used to provide a point of comparison between vulnerabilities and to help prioritize their remediation. Scores are calculated based on a formula released by the Forum of Incident Response and Security Teams (FIRST) that factors in a variety of metrics approximating ease of exploit, scope and impact. Scores range from 0 to 10, with 10 being the most severe.

[Common Vulnerability Scoring System V4.0](#) (CVSS 4.0)

Severity	Score	Explanation
Critical	9.0-10.0	Vulnerabilities in this category should be monitored closely by management and addressed as soon as possible.
High	7.0-8.9	Vulnerabilities in this category can have a significant impact on confidentiality, availability or integrity.
Medium	4.0-6.9	The exploit of vulnerabilities in this category might require additional data or vectors from the attacker to be successful.
Low	0.1-3.9	While the vulnerability is not severe, it poses a potential security risk and should be addressed.
Informational	0.0	Vulnerability should be remediated to meet industry best practices.

Team-XX has also implemented a methodology for assessing the likelihood of vulnerability exploitation. The measurement is categorized into three levels: High, Medium and Low. These levels, shown below in [table X](#), provide a nuanced understanding of the probability a vulnerability is exploited, focusing primarily on ease of exploitation and existing security features.

Likelihood	Explanation
High	Exploitation is likely, the vulnerability is easily discoverable and does not require significant prior knowledge or other information to exploit.
Medium	Exploitation is expected to happen at times, however the exploit may require prior knowledge to leverage or is not easily discoverable.
Low	Exploitation is improbable due to the complexity of the exploit, the prior knowledge required of the attacker, and the existing security features.

Team-XX's comprehensive approach to risk assessment, combining both likelihood and severity as outlined below in Table X, provides a holistic view of cybersecurity threats. This integrated approach to vulnerability assessment aids in strategic resource allocation and improves communication with stakeholders. By prioritizing vulnerabilities based on both impact and likelihood, organizations can efficiently allocate resources to address the most significant threats.

Risk Matrix

Risk Matrix		Impact (CVSS Score)				
		Informational	Low	Medium	High	Critical
Likelihood	Low	Informational	Low	Low	Medium	High
	Medium	Informational	Low	Medium	High	Critical
	High	Informational	Medium	Medium	High	Critical

Technical Findings

Findings Count					
Severity Rating	Critical	High	Medium	Low	Informational
Vulnerabilities	#	#	#	#	#

Findings	Severity Level	Affected Scope
C-01:	Critical	
H-01:	High	
M-01:	Medium	
L-01:	Low	
I-01:	Informational	

Remediation Summary

This table summarizes findings from the previous assessment, categorized into: **Remediated** (no longer poses risk, fully fixed), **Partially Remediated** (risk reduced but still present), and **unremedied** (same, unchanged risk level as previous assessment).

Finding Name	Status
Critical	Unremedied
High	Partially Remediated
Medium	Remediated
Low	Remediated
Informational	Partially Remediated

Critical Findings

C1: Weak Administrator Password

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003: Password Spraying	
	Mitigations	M1027: Password Policies M1032: Multi-Factor Authentication	
Affected Scope			

Description

The **affected host's admin local user account** was found to be using a weak password that was successfully guessed using a dictionary-based brute force password attack. This led to the compromise of the **admin account**.

Business Impact

This vulnerability can lead to operational disruptions, as an attacker with administrative privileges on the host can disrupt systems.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Implement and enforce a strong password policy for all accounts to ensure attackers are unable easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters

Confidential

- b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.
 - c. Unique passwords for each user and service to prevent password reuse
- 2. Implement a lockout policy to block attackers after repeated failed login attempts, preventing them from brute forcing credentials.
- 3. Implement multi-factor authentication to prevent access even with leaked or disclosed passwords.

References

<https://www.digicert.com/blog/creating-password-policy-best-practices>

High Findings

H1: Weak Administrator Password

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1552.001 - Unsecured Credentials: Credentials in files	
	Mitigations	M1047: Audit M1027: Password Policies	
Affected Scope			

Description

The FTP server permitting anonymous logon hosts sensitive information, including plaintext credentials for system users allowing an attacker to gain a foothold on the network through the leaked credentials.

Business Impact

An attacker can use the exposed credentials to gain unauthorized access to other systems and applications within the network, potentially leading to a full system compromise. This can result in sensitive data being stolen, financial loss, and reputational damage.

Steps to Reproduce

Step 1: Log into the FTP server with anonymous access

Step 2: Recursively list the files on the server to identify sensitive files with 'ls -R'.

Step 3: Download any suspicious files using the get command.

Step 4: Examine the contents of the downloaded file **X** and confirm the presence of plaintext credentials.

Confidential

Remediations

Team-XX recommends the following:

1. Disable anonymous access by modifying the FTP server configuration file to disallow anonymous logins if sensitive/confidential information is stored on the server.
2. Audit and remove any sensitive files from the FTP Server directories. Implement a strong policy against storing such information on network shares.
3. Implement firewall policies to block the FTP server from being accessible from the outside internet and only from trusted internal network segments.

References

[Cerberus - How to Secure an FTP Server](#)

[Phoenixnap - Configuring Firewall with UFW on Ubuntu](#)

Medium Findings

M1: Public Access to WP-Cron.php

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.8	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1054: Software Configuration M1042: Disable or Remove Feature or Program	
Affected Scope			

Description

An attacker can exploit the WP-Cron.php script, which is used to schedule and run background tasks on WordPress, by repeatedly hammering it with requests in an

Confidential

attempt to cause a Denial of Service (DOS) attack. Successful exploitation impacts the availability of the WordPress website for all users.

Business Impact

This will cause server performance to be impacted and could cause the website to become unavailable due to a high number of resources being used by the attacker, impacting the availability of the WordPress server.

Steps to Reproduce

As this penetration test was run against the live production environment, **Team-XX** did NOT run any exploits that would impact the availability of the system, preventing other users from being able to perform regular customer and employee workflow. However, we know the vulnerability is present because:

Step 1. Visit /wp-cron.php

Step 2. Observe that the server does not issue a 404 status, or a similar response

Remediations

Team-XX recommends the following:

1. Block any external IP address from accessing WP-Cron.php by explicitly denying all incoming requests in the .htaccess file.
2. If the WP-Cron service is not in use or required, it is highly recommended to disable the feature to reduce attack surface.

Resources

[In-Motion Hosting: WP-Cron Security Management](#)

Low Findings

L1: SMTP Unenforced DKIM and DMARC

Matrix Calculation		CVSS Score	Risk
Impact	Medium	2.3	Low
Likelihood	Low		
CVSSv4.0 Attack Vector		<u>AV:N/AC:H/AT:N/PR:L/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1534: Internal Spearphishing</u> <u>T1598: Phishing for Information</u>	
	Mitigations	<u>M1054: Software Configuration</u>	
Affected Scope			

Description

The SMTP server is missing a DMARC and DKIM record. Unenforced DMARC allows an attacker to spoof the domain in phishing attacks by allowing unauthorized use of the domain in the Friendly-From address of email messages. Unenforced DKIM means that verification of senders is not performed on the SMTP server, enabling users to more easily perform phishing campaigns on ATP employees.

Business Impact

Attackers can abuse this misconfiguration to perform domain spoofing in targeted phishing campaigns on ATP employees. These emails will not be verified as coming from internal ATP employees but will appear to be coming from the ATP domain. This will make phishing attempts much harder to detect and will likely result in increased employee interaction with malicious, phishing emails.

Steps to Reproduce

Step 1: `swaks -ehlo user@domain -from name@domain -to user@domain -server smpt.server.local --h-From "'Name' <name@domain>' --attach-type text/html --attach-body @Mail-template.html`

Confidential

Remediations

Team-XX recommends the following:

1. Enforce DMARC by adding a record to the domain and specifying the enforcement policy to quarantine or reject emails containing a mismatch between sender and from, which is likely to be a domain spoofing attempt.
2. Enforce DKIM which will verify domain identities when sending emails.
3. Implement email quarantining and filtering to block malicious emails and phishing attempts from being delivered to employee inboxes.

Reference

[RackSpace - Create a DMARC Policy](#)

[RackSpace - Enable DKIM](#)

[Higherlogic - SPF, DKIM, DMARC Email Authentication](#)

Informational Findings

I1: Excessively Privileged Application

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1611: Escape to host T1098: Account Manipulation	
	Mitigations	M0926: Privileged Account Management	
Affected Scope			

Description

The **API** service is running as a privileged user, significantly increasing the effectiveness of chain exploits. An attacker running commands will end up running those commands as privileged user, giving them increased access and permissions to backend files and services.

Business Impact

If the **SERVICE** service is exploited, an attacker will immediately have privileged access on the backend system. This misconfiguration significantly increases the criticality of any other vulnerability, as it is run by an excessively privileged user.

Steps to Reproduce

Step 1: Check what user is running the program by running “ps -p XXX”

Step 2: Check the users' permissions by running “id user”

Remediations

Team-XX recommends the following:

Confidential

1. Implement the Principle of Least Privilege so that non-privileged system accounts have only the minimum permissions required to function.
2. Creating service accounts with limited access, following the Principle of Least Privilege.
3. Regularly audit user and system account permissions to ensure no privilege creep occurs over time.

References

[CrowdStrike - Principle of Least Privilege](#)

Appendix

Appendix A – Compromised Accounts

During the engagement, the following accounts' credentials were discovered, and the accounts were subsequently compromised. The credentials for these accounts should be immediately changed to prevent further unauthorized access to internal systems and accounts.

Username	Type/Privilege	Method of Compromise
Admin	Administrator	FTP Leakage
AndyG	User	Weak Credentials

Appendix B – Tools Used

Tool	Description
Metasploit	A modular exploitation and post-exploitation framework used to run common exploits against remote systems.
Impacket	A collection of Python classes and scripts that implement low-level network protocols (SMB, MS-RPC, Kerberos, etc.) used for exploiting Windows networking services.
Nmap	A fast, flexible network scanner for discovering hosts, open ports, and basic service/version information; frequently used for initial reconnaissance and service enumeration.
Burp Suite Community Edition	Local Web Proxy for inspecting and manipulating HTTP(S) requests. Allows for intercepting, manipulating, and crafting malicious requests to web applications.

<u>Netexec</u>	A lightweight remote command execution utility used to run commands on a remote host over a simple TCP connection; useful for quick interactive access in lab or controlled engagement environments. Compatible for enumeration and exploitation of SMB, LDAP, WINRM, and other Windows protocols.
<u>Gobuster</u>	A directory, DNS and virtual host brute-forcing tool written in Go, used to discover hidden files, directories, and subdomains on web servers by wordlist enumeration.
<u>Enum4linux-ng</u>	A tool for enumerating information from Windows (shares, users, groups, policies) via SMB/RPC protocol interactions; useful for gathering host and domain details during network reconnaissance.
<u>FFUF</u>	A fast web fuzzer for discovering hidden resources, parameters, and inputs by substituting words from wordlists into URL paths and request components.
<u>Hashcat</u>	A high-performance password cracking tool that performs dictionary, rule-based, and brute-force attacks against password hashes.
<u>Hydra</u>	A parallelized network login cracker supporting many protocols (SSH, RDP, HTTP, SMB, etc.) used for rapid credential guessing/testing during credential-validation phases.
<u>John</u>	A versatile password cracking tool that supports many hash formats and cracking modes; often used for offline password hash cracking.
<u>Kerbrute</u>	A fast Kerberos username enumeration and password spraying tool for Active Directory environments; typically used to identify valid accounts and test weak Kerberos credentials.

<u>Wfuzz</u>	A flexible web application fuzzer for brute-forcing GET/POST parameters, testing hidden resources, and probing for injection points using customizable payloads.
<u>GoPhish</u>	An open-source phishing campaign framework for creating, sending, and tracking phishing emails and landing pages in red-team or security awareness exercises.
<u>Maltego</u>	A graphical link-analysis tool for OSINT that maps relationships between people, domains, infrastructure, and other entities to visualize attack surfaces and gather external intelligence.
<u>Aquatone</u>	A reconnaissance tool that takes screenshots of web hosts across a domain (usually from subdomain enumeration) to quickly identify interesting web assets and potential targets.
<u>SQLMap</u>	An automated tool for detecting and exploiting SQL injection vulnerabilities and for performing database takeover and data extraction in a controlled testing context.
<u>PEASS-NG</u>	A set of local privilege escalation enumeration scripts (Windows/Linux) that automate discovery of common misconfigurations and vectors to help identify potential privilege escalation paths.
<u>BloodHound</u>	A graph-based Active Directory analysis tool that models permissions and relationships to find attack paths (e.g., privilege escalation and lateral movement) in AD environments.
<u>Ligolo-ng</u>	A tunneling tool that creates TCP/UDP tunnels over an encrypted channel, often used to proxy traffic through a compromised host for pivoting in segmented networks.

Certipy	A tool for auditing and abusing Active Directory certificate services (AD CS); helps identify certificate-based attack vectors and perform certificate-related reconnaissance.
Mimikatz	A post-exploitation tool for extracting plaintext credentials, Kerberos tickets, and credential artifacts from Windows memory and secure stores; commonly used to demonstrate credential exposure risks.
Rubeus	A C# toolset for interacting with Kerberos on Windows (requesting/renewing tickets, abusing service tickets) used in Kerberos-centric assessments and AD attacks.
BloodyAD	A collection/automation of offensive AD techniques (enumeration, abuse, exploitation) that wraps multiple capabilities useful for Active Directory assessments.
SWAKS	A versatile command-line SMTP testing tool for crafting and sending customized email messages, useful for testing mail server behavior and phishing infrastructure.
LaZagne	A credentials recovery tool that searches for a local machine for stored credentials from many applications (browsers, mail clients, databases) to assess persistence of secrets on endpoints.
Evil-WinRM	A PowerShell Remoting (WinRM) client designed for red teamers that provides an interactive shell and file transfer for Windows hosts where WinRM connectivity is available.
LDAPSearch	A command-line LDAP query utility for retrieving directory objects, attributes, and schema; used to enumerate users, groups, service accounts, and metadata during Active Directory reconnaissance.
CyberChef	A browser-based “recipe” tool for decoding, encoding, transforming, and parsing data (hashes, tokens, logs);

	used for rapid on-the-fly analysis and format conversion during triage and exploitation workflows.
Responder	A network responder/poisoning framework for LLMNR/NetBIOS/mDNS that captures authentication attempts (NTLM/Net-NTLMv2) and service requests.

Appendix C - Methodology

TODO

- Pentesting standards
 - o http://www.pentest-standard.org/index.php/Main_Page
- OSINT
- Phishing
 - o <https://www.nist.gov/publications/nist-phish-scale-user-guide>

OWASP Top 10

OWASP Top 10 is a standard web application security framework that is a representation of the most critical and commonly seen security risks pertaining to web applications. This table highlights the critical vulnerabilities present within the web applications in APT's infrastructure.

Vulnerability	Test Results
Broken Access Control	FAIL
Cryptographic Failure	FAIL
Injection Insecure Design	FAIL FAIL
Security Misconfiguration	FAIL
Vulnerable and Outdated Component	PASS
Identification and Authentication Failures	PASS

Software and Data Integrity Failures	PASS
Security Logging and Monitoring Failures	PASS
Server-Side Request Forgery	PASS

Appendix D – CVSS 4.0

Team-XX utilized the Common Vulnerability Scoring System (CVSS) during the engagement to classify the severity level of each discovered vulnerability. CVSS is a common, industry standard scale that calculates the severity of a vulnerability based on important factors including attack complexity, scope, permissions required, subsequent system access, and impact on confidentiality, integrity, and accessibility. CVSS 4.0, implemented in 2023, was utilized as it is the most modern implementation of the scoring system. All findings were reported on a rating from (0.0-10.0) with the relevant CVSS scoring calculations linked for ease of use.

Appendix E – MITRE ATT&CK Framework

The MITRE ATT&CK Framework is a global knowledge base of real-world adversary tactics and techniques. The ATT&CK knowledge base is used for a foundation of specific threat modeling, to allow defensive security teams to better understand and stop advanced threats and cyber-attacks. MITRE provides specific remediations for all tactics and techniques to inform defensive security operations teams and the best ways to defend against adversary threats. Relevant MITRE techniques and remediations were provided for all findings to better inform ATP on how each finding could be exploited and remediated.

Appendix F – Artifacts

During the course of the engagement, **Team-XX** modified parts of APT's network to aid in vulnerability discovery. All artifacts were removed before the end of the engagement to ensure the network attack surface was not further increased through the processes performed in the engagement.